SECURITY

JWT
Visual Guide

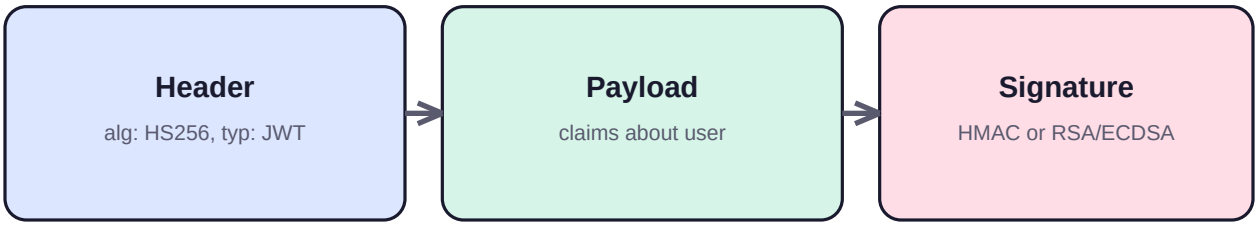
JSON Web Tokens —
compact, signed, self-contained credentials.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

Anatomy: Three Segments

Header . Payload . Signature — base64url, dot-separated.



The payload is only base64url-ENCODED, not encrypted — anyone can read it. Never put secrets in claims.

STEP 2/6

Claims: What Tokens Say

Three claim flavors, one contract.

Registered

iss, sub, aud, exp, iat, nbf, jti

Public

standard names, safe to share

Private

app-specific (roles, tenant)

Keep tokens small: a handful of claims. Everything you add rides on every request.

STEP 3/6

Validation: The Six Checks

Run all of them, every time, server-side.

1. Signature

recompute with the right key

2. Issuer

iss matches your IdP

3. Audience

aud is YOUR service

4. Expiry

exp in the future

5. Not-before

nbf in the past

6. Replay

jti not seen before (sensitive ops)

STEP 4/6

Pitfalls That Burn People

Real attacks, still seen in the wild.

alg=none

Attacker strips the signature. Fix: whitelist allowed algorithms.

Weak HS256 secret

'secret123' brute-forced offline. Fix: 256-bit random key, or use RS256.

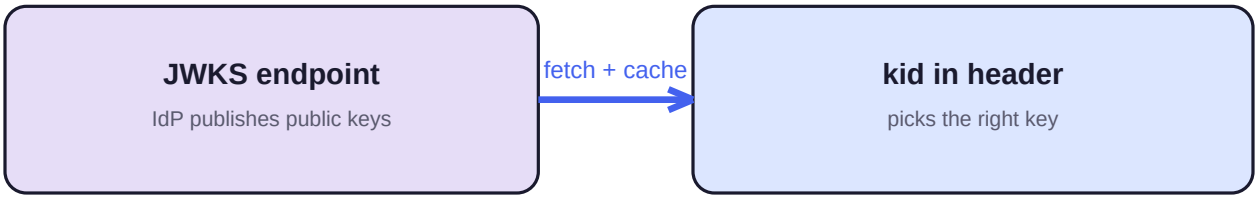
No expiry / giant lifetime

Stolen token works forever. Fix: short exp + refresh tokens.

STEP 5/6

Key Rotation with JWKS

Keys change; tokens keep validating.



- Sign with RS256/ES256 (asymmetric) so verifiers only need public keys.
- Cache the JWKS; respect cache headers; handle key rollover gracefully.
- Rotate signing keys on a schedule and after any suspected compromise.

STEP 6/6

Tokens vs Sessions — When

Stateless is fast; stateful is revocable.

JWT access tokens

Stateless, short-lived (minutes). Great for APIs.

Server sessions

Instantly revocable. Great for web apps + admin.

Classic pattern: short-lived JWT access token + rotating refresh token stored server-side. Best of both worlds.

STEP ✓I✓

Key Takeaways

JWT — Remember

- JWT = header.payload.signature; payload is readable, not encrypted.
- Validate six things: signature, issuer, audience, expiry, not-before, replay.
- Kill alg confusion: whitelist algorithms, use strong random keys or RS256/ES256.
- Rotate signing keys via JWKS; keep tokens short-lived with refresh tokens.
- Short JWT for APIs, server sessions where instant revocation matters.

Keep exploring

Pair this guide with the matching video walkthroughs
and hands-on labs at interstitiumlabs.dev